

Comp 1608 - Managing IT and Security Risk

Tasks Report

Ayaan Jalal Sayyad

00140855

Computer Forensics and cybersecurity

Table of Contents

Summary	1
Task 1	2
1. Network segmentation and Access Control Overhaul:	2
2. Upgrading Key Infrastructure and Endpoints:.....	2
Task 2	3
1. Network segmentation and Access Control Overhaul:	3
2. Upgrading Key Infrastructure and Endpoints:.....	5
Task 3	6
Task 4	9
Conclusion	10
References	10
Appendix A: Declaration of AI Use	11

List of Tables

Table 1: Qualitative Risk Matrix.....	8
---------------------------------------	---

Summary

This report evaluates MegaCorp's current posture and identifies key vulnerabilities in its infrastructure and processes. Task 1 presents 2 recommendations that will have high impact on security, Task 2 provides a structured plan to implement that recommendation. Task 3 talks about threats relevant to MegaCorp's security and recommendations to mitigate them and finally Task 4 discusses 5 changes the organization can make to better align itself with PCI DSS.

Task 1

After reviewing MegaCorp's security posture, several structural weaknesses were found that can expose the organization to risks such as operational risks and compliance risks, etc. While multiple areas require improvement, these 2 recommendations will definitely help strengthen MegaCorp's security posture while providing high return on investment:

1. Network segmentation and Access Control Overhaul:

MegaCorp's network is mostly flat meaning all devices are part of the same network segment and can communicate directly with each other without going through intermediary devices like routers. There is no separation between production system and testing system and shared drives hold the potential to expose sensitive client data. Additionally, some legacy equipment from the Initech merger has been integrated without a proper review which poses a risk and if an attacker gains access to any device they can move freely across the network and may attack critical infrastructure.

Implementing proper network segmentation would significantly reduce exposure and creating separate dedicated zones for systems would prevent unauthorized movement between environments Both segmentation and access control overhaul will limit the impact of breaches and also helps strengthen compliance obligations

2. Upgrading Key Infrastructure and Endpoints:

MegaCorp relies on a large number of outdated operating systems and legacy devices such as CentOS 6.x and ageing network equipment. These devices and equipment have passed their EOL which stands for end-of-life support and no longer receive security patches and updates. This exposes the organization to well-known vulnerabilities and increases the likelihood of compromise.

Simply upgrading the physical devices such as PCs, laptops and servers to currently supported versions would immediately reduce the attack area. Modern devices will receive patches and centralized security updates; all the systems will have a configuration baseline while also ensuring compatibility with GDPR and PCI DSS. Additionally upgrading would improve operational continuity, reduce downtime and give access to more stable and secure platform.

This investment is for long-term resilience and prepares MegaCorp for more advanced security practices.

Task 2

After reviewing MegaCorp's information that has been provided several vulnerabilities can be found. The organization has outdated server like the CentOS 6.x and windows 2012 along with outdated Windows and macOS endpoints. MegaCorp's network structure is mostly flat and there is no logging, vulnerability management, patch control and employees retain administrator rights on their devices. The development, testing and production environments are not separated and sensitive data is stored on shared drives. These weaknesses increase exposure to data breaches and can lead to operational disruptions. Research shows that small and medium sized organization often suffer from similar weakness such as outdated systems or lack of patching which increases their risk of cyber-attack (Chidukwani, Zander and Koutsakis, 2022)

After doing a qualitative risk assessment (likelihood x impact), MegaCorp's faces high organizational risks. As discussed in lectures, risks arises when valuable assets are exposed to threats through vulnerabilities and these vulnerabilities increase both the likelihood of compromise and the potential impact on customer data.

To deliver the recommendations identified in task 1, a structured plan with realistic goals is required. Considering MegaCorp's resources and security posture this plan ensures that improvements are delivered using the 5Cs framework. The following schedule outlines the teams involved along with the process they will follow and expected timelines.

1. Network segmentation and Access Control Overhaul:

i) Objective-

The objective of this recommendation is to redesign MegaCorp's network to protect critical assets by separating them into secure zones. The aim is to reduce lateral movement and prevent exposure if one or the other environment is compromised and also ensuring that users only access resources relevant to their roles and also compliance with GDPR and PCI DSS. This also aims to strengthen the overall resilience of MegaCorp's IT environment.

ii) Teams Involved-

- Network Infrastructure team
- Cybersecurity team
- IT operation team

- Initech Integration Team
- Change control board
- External Consultants

iii) Methodology-

To deliver this recommendation the very first phase would involve a full assessment of the existing network. Here the cybersecurity team and network infrastructure team would map out the traffic flow and devices that are necessary for operation including the devices inherited from Initech. Understanding the current environment is essential before any changes can be made.

Next phase is to design a segmentation model. This includes creating separate zones for production, development, testing, administrative systems, employee devices and restricted contractor network. Plan to implement firewalls and access control would help control movement between these zones, supported by RBAC (Role based access control) policies that define exactly each team or role can access. RBAC improves security by assigning permissions on job functions, reducing privilege misuse and enforcing least privilege. (Zhu and Zhou, 2008)

The third phase which will plan to implement all the designs. This will start with submitting these designs given in phase 2 to Change Control Board (CCB) for approval. This will ensure that implementation will not disturb business operations and operations are scheduled in advance. This will be done gradually starting with lower risk systems before moving to production environments. Some jobs carried out by IT and will include configuring VLANs, applying firewall rules and migrating devices into their dedicated zones. A special isolated zone for Initech will be used until the devices inherited can be upgraded or replaced.

When the technical work is complete, testing would be carried out. New documentation will be created with new network diagrams that represent changes made. Staff will be informed about any changes to permission or access to ensure a smooth transition.

In the fourth phase the cybersecurity team will start logging data, firewall alerts, etc to ensure smooth working of segmented zones as intended. Quarterly access reviews would also take place to maintain accurate RBAC settings as teams and roles change over time.

iv) Assumptions-

- Availability of downtime
- The Hardware and software which will support VLANs
- The hardware and software which will support ACLs or access control list.

v) 5Cs consideration-

This recommendation aligns with the 5Cs, a structured **change** is discussed, improvements in **compliance**, long term **cost** benefits by reducing risks, strengthening of **continuity** and broad **coverage** of the organization.

2. Upgrading Key Infrastructure and Endpoints:

i) Objective-

The aim of this recommendation is to upgrade MegaCorp's outdated and unsupported systems such as endpoints and network devices. These systems reached end-of-life leaving the organization exposed to well-known vulnerabilities. Upgrading will not only reduce the likelihood of the cyber-attacks but also improve overall stability, compatibility with security tools, alignment with GDPR and PCI DSS requirements.

ii) Teams Involved-

- IT infrastructure team
- Cybersecurity team
- Procurement team
- Change Control Board

iii) Methodology

MegaCorp's upgrades and segmentation require a structured approach to organizational change, consistent with guidance that successful change depends on clear direction and communication. (By, 2007)

The first phase of this recommendation is to perform a full audit of existing hardware and software estate. This will include identifying old OS, cataloguing end-of-life hardware and prioritising critical servers that are important to business operation.

Once the audit is complete, the next step is to design the upgrade plan. The infrastructure team will decide on new hardware and where it is needed to be replaced. Budget will be estimated and presented to the management, and after financial approval the plan can be taken to the Change Control Board for evaluation.

The upgrade phase will begin with a small group of devices to test compatibility. The testing phase ensures that application and user functions work correctly on the new platform. If this proves to be successful rollout will occur in phases. Critical servers and

production systems will be upgraded during scheduled maintenance including user endpoints. Legacy equipment from Initech will be isolated until migration is complete.

In the rollout phase enhancements such as device hardening and baseline configuration will be applied. After the implementation is complete, the IT operations team will create new guidelines and train staff for new changes to the operating system.

Finally, the last phase will assess stability and performance and any remaining legacy systems will be tracked or upgraded.

iv) Assumptions

- Management will approve the budget.
- Suitable downtime can be scheduled without disrupting operation.
- Required vendor licences are available
- Staff devices and application will become compatible with new OS
- The IT team will have access to documentation and resources needed for the process.

v) 5Cs consideration

This recommendation supports change management by following a controlled phased rollout. It improves compliance by removing unsupported systems and aligns better with PCI DSS requirements. There is initial cost but it is considered long term security issues which could cost more. Continuity is strengthened because modern devices are stable and reliable, and finally this upgrade provides broad coverage from server and network devices to endpoints.

Task 3

The following sections explain each threat, its impact on MegaCorp, and the recommended control to reduce or mitigate the associated risk.

1. Exploitation of outdated operating system

An outdated operating system can have serious vulnerabilities and failure to address these vulnerabilities may result in operational shutdown and potentially jeopardise the organization's future. Implementing a structured upgrade programme that replaces all outdated OS with supported and patched version and ensuring that every device meets current security standards and is protected against known vulnerabilities.

This weakness when exploited can lead to service outages and interruption costing the organization time and money. Compromised OS can also be exploited in such a way that it can lead to business shutdown and violate GDPR guidelines.

To illustrate, attackers will be able to exploit known weaknesses that are no longer patched and these are publicly documented in database such as the Common Vulnerabilities and Exposures (CVE) system allowing attackers to gain access with minimal effort(Thiyagarajan, Bist and Nayak, 2025). They can easily run malicious code or steal data potentially compromising the organization and even personal data of customers.

2. Lateral movement due to flat network

Lateral movement is a major concern in a flat network because once an attacker compromises a single device, they can move freely through the whole network without restrictions allowing them to do things that are harmful to the organization. They access sensitive information or steal credentials even spread malware or ransomware. (Duvvur, 2022)

Deploying network segmentation together with internal firewalls ACLs and policies to restrict internal traffic and prevent attackers from moving freely across the organization

To illustrate, an attacker gains access to a laptop through a phishing email. Since it's a flat network the attacker can quietly move into different environments and servers without raising an alert. They can disrupt operations and steal information.

3. Data leakage from shared drives

Data leakage from shared drive occurs when sensitive files are stored in locations that are accessible to users who do not need that information for their job. Confidential client data and documents are stored on shared drives without proper segmentation.

Introducing strict access controls and a formal data classification policy so that only authorized users can access sensitive folders and migrating confidential files into proper role-based locations.

Impact on MegaCorp's can be serious if sensitive client data is leaked and organization could face GDPR violations and legal penalties. This could also weaken their competitive position. In extreme cases relationship with clients could decline trust and even lead to halting of operations.

To illustrate, if an attacker compromises a low-privilege employee account, they can still browse shared drive and download sensitive information as they are not restricted allowing confidential information to be stolen without needing elevated permissions.

4. Privilege abuse

Privilege abuse is when an employee misuse permission to access system or files they are not allowed to. Here, users have admin level rights. This creates a serious security and compliance risk for MegaCorp, potentially exposing confidential data and critical systems.

Implementing strict privilege access controls and removing unnecessary administrator right and ensuring regular privilege reviews to ensure users only have access to what they need. Blocking of unauthorized file movement should also be implemented(Gupta and Agarwal, 2024)

To illustrate, an attacker which can also be an employee can disable protection mechanisms such as antivirus or VPN and even install a malware to sabotage the organization.

5. Ransomware attack due to no patching and backup

Ransomware encrypts files and systems locking users out until ransom is paid. In MegaCorp's case, the absence of backups means that there would be no clean copies of data to restore, forcing the organization to pay the ransom.

Implementing a centralized patch management programme and performing regular backups will ensure help mitigate this vulnerability

To illustrate if an attacker exploits an unpatched server, they can deploy ransomware and this could encrypt drives and productions systems, etc. The company could lose access to all critical files and have no way to recover them. This could lead to business shutdown while systems are rebuilt either by paying the ransom or from scratch.

Risk Scenario	Likelihood	Impact	Overall Risk
Outdated OS exploited by attackers	High	High	Critical
Lateral movement in a flat network	High	High	Critical
Data Leakage from shared drives	Medium	High	High
Privilege abuse	Medium	Medium	Medium
Ransomware attack due to no patching and backup	Medium	High	High

Table 1: Qualitative Risk Matrix

Task 4

Here are the 5 most impactful changes that can have the highest impact to align the organization with PCI DSS.

1. Implementing Network segmentation to isolate the cardholder data environment (CDE)-

PCI DSS strongly suggest that organizations to separate the CDE from the wider corporate network so that only essential systems handle payment information. MegaCorp's flat network structure increase the risk of unauthorized access to cardholder data and results in a compliance burden. As discussed previously implementing VLANs and firewalls and RBAC, MegaCorp can isolate the CDE and limit incoming and outgoing traffic to only authorized users. This not only strengthen the network but also aligns the organization with PCI DSS standards.

2. Implementing multi-factor authentication (MFA)-

MFA is another high impact change that would align MegaCorp with PCI DSS v4. It explicitly requires MFA for all non-console administrative access and for any user accessing the CDE ensuring that only a password alone is never sufficient for logging in. If an attacker gain access by malware or social engineering, they can access sensitive information without any additional authentication. MFA can be implemented using apps such as authenticator or biometric systems like windows hello. This make unauthorized access harder even if passwords is guessed or stolen. By enforcing MFA across all administrative accounts MegaCorp would greatly reduce the risk of account compromise while ensuring it meets PCI DSS requirements.

3. Implementing centralized logging and monitoring-

Centralized logging and monitoring is also a critical change as it directly supports requirement 10, which mandates the tracking and monitoring of all access to system components and cardholder data. Without a centralized logging the organization will not be able to effectively identify threats or incidents and even respond to them in a timely manner. Implementing a security information and event management system (SIEM) would allow MegaCorp to collect logs from different devices and allow them to analyse those logs to respond to incidents. Additionally, PCI DSS requires audit logs to be protected from alteration and retained for 1 year.

4. Conducting regular penetration testing and vulnerability management-

Conducting regular penetration testing and vulnerability management is high impact for MegaCorp for aligning with PCI DSS because it directly satisfies requirement 11 which

mandates routine internal and external vulnerability scans and annual penetration tests to identify weaknesses. These activities allow the organization to fix vulnerabilities quickly and to dramatically help improve its security posture and reduce the likelihood of attack.

5. Strengthen physical security controls-

This satisfies requirement 9 of PCI DSS as it requires organizations to have strict physical access to the CDE using measures such as access badges, CCTV and locked server rooms. Currently MegaCorp does not have any physical system in place which potentially increases the risk of hardware tampering, data theft or even access to ports. By simply installing locks and CCTV and also using logs to keep track of visitors MegaCorp can ensure only authorized personnel can interact with sensitive systems. Additionally, regular audits will help with security and not only help align with PCI DSS v4 but keep the organization safe.

Conclusion

In conclusion assessing MegaCorp's security posture reveals several critical weaknesses that increase its exposure to common threats and attacks. This report provides recommendations to improve security in task 1 and task 2 expand on these recommendations by giving a structured way to implement them. More research about threats is done regarding to MegaCorp and the impact that the threats will have on the organization and how to counter those threats. Furthermore also discussed is the compliance with PCI DSS and recommendations provided. With these weaknesses addressed and the recommendations provided along with steps will help MegaCorp improve its security posture, and build a more secure and stable organization.

References

- By (2007) 'Journal of Change Management Organisational change management: A critical review Rune Todnem By'. Available at: <https://doi.org/10.1080/14697010500359250>.
- Chidukwani, A., Zander, S. and Koutsakis, P. (2022) 'A Survey on the Cyber Security of Small-to-Medium Businesses: Challenges, Research Focus and Recommendations', *IEEE Access*, 10, pp. 85701–85719. Available at: <https://doi.org/10.1109/ACCESS.2022.3197899>.
- Duvvur, V. (2022) 'Securing the Future: Strategies for Modernizing Legacy Systems and Enhancing Cybersecurity', *Journal of Artificial Intelligence & Cloud Computing*, 1(3), pp. 1–3. Available at: [https://doi.org/10.47363/JAICC/2022\(1\)299](https://doi.org/10.47363/JAICC/2022(1)299).

- Gupta, S. and Agarwal, S. (2024) 'Evolving Cyber Security Threats and Adaptive Defence Mechanisms: A Comprehensive Approach to Modern Challenges'. Available at: <https://doi.org/10.1109/UPCON62832.2024.10983101>.
- Thiagarajan, G., Bist, V. and Nayak, P. (2025) 'The Hidden Dangers of Outdated Software: A Cyber Security Perspective', *International Journal of Scientific Research in Computer Science, Engineering and Information Technology*, 11(2), pp. 2925–2938. Available at: <https://doi.org/10.32628/CSEIT25112772>.
- Zhu, H. and Zhou, M.C. (2008) 'Roles in information systems: A survey', *IEEE Transactions on Systems, Man and Cybernetics Part C: Applications and Reviews*, 38(3), pp. 377–396. Available at: <https://doi.org/10.1109/TSMCC.2008.919168>.

Appendix A: Declaration of AI Use

I have used AI while undertaking my assignment in the following ways:

- To develop research questions on the topic – yes
- To create an outline of the topic – No
- To explain concepts – No
- To support my use of language – YES
- To summarise the following articles/resources: No
- In other ways, as described below:

Used AI to structure the sentence and to find synonyms/ better words for my tasks.